Relatório técnico — confidencial

Domínio carretolages.com

segurança e passagem para a Cloudflare

O que foi encontrado no site e no email atuais, os riscos, como resolver e os passos para alojar o novo site na Cloudflare

Data da análise:	6 de novembro de 2026
Domínios:	`carretolages.com` (principal) e `carretolages.eu`
Site atual:	`https://www.carretolages.com` (WordPress, alojado na PTisp)
Site novo:	`https://carretolages.pages.dev` (pré-visualização)

Análise feita apenas com informação pública: pedidos normais a páginas do site, consultas DNS e serviços públicos de reputação. Não houve tentativas de entrar no site, no painel de alojamento nem no email. Este documento descreve falhas de segurança ainda abertas: deve ser partilhado só com quem vai tratar delas.

Conteúdo

1 Resumo **2**

2 O que foi encontrado **3**

2.1 Artigos de spam publicados no site . . . 3
2.2 Conta de administrador desconhecida . . . 3
2.3 Software sem atualizações de segurança . . . 6
2.4 Site e email no mesmo servidor . . . 7
2.5 Informação exposta e login aberto . . . 7
2.6 Conteúdo de demonstração publicado . . . 8
2.7 Ligações para domínios abandonados . . . 10
2.8 Sem cabeçalhos de segurança . . . 10
2.9 DNS e email: pormenores a corrigir . . . 12
2.10 O que está bem . . . 12

3 O que fazer já, antes da mudança **13**

4 Passos para passar para a Cloudflare **14**

4.1 Fase 0 — Preparação (sem impacto no site nem no email) . . . 14
4.2 Fase 1 — Criar a zona na Cloudflare . . . 14
4.3 Fase 2 — Ligar o site ao domínio . . . 15
4.4 Fase 3 — Mudar os nameservers (a mudança propriamente dita) . . . 15
4.5 Fase 4 — Depois da mudança . . . 16

A Endereços antigos e para onde vão **16**

B Como foi feita a análise **17**

1 Resumo

O site atual do escritório foi atacado e continua comprometido. Desde outubro de 2023, alguém publicou no site 5 artigos de spam: programas pirateados ("crack" de Photoshop, Ableton, Adobe Premiere) e réplicas de relógios Rolex. Esses artigos aparecem na secção "Destaques", com o cabeçalho, o logótipo e os contactos do escritório. Um dos artigos foi publicado por uma conta de administrador chamada `admin` que não pertence a ninguém do escritório nem à empresa que fez o site.

O site corre em software com 2 a 10 anos de atraso e está no **mesmo servidor do email**. Quem controla o site pode, potencialmente, chegar ao alojamento e ao email.

Boas notícias: o Google não marca o site como perigoso, o servidor e o domínio não estão em listas negras de spam e o email tem as proteções principais (DKIM e DMARC) bem configuradas.

O que recomendamos:

1. **Esta semana:** mudar todas as palavras-passe (PTisp, cPanel, email, WordPress), apagar a conta `admin` e os artigos de spam e pedir à PTisp uma análise de malware ao alojamento (secção 3).
2. **Substituir o site** pelo site novo, alojado na Cloudflare Pages: é estático, não tem base de dados, painel de login nem PHP, por isso este tipo de ataque deixa de ser possível.
3. **Manter o email na PTisp** exatamente como está e passar apenas a gestão do DNS e o site para a Cloudflare (secção 4).
4. **Desligar o WordPress** depois de o site novo estar no ar.

Quadro de riscos

#	Problema	Gravidade	Resolução
2.1	Site comprometido: 5 artigos de spam publicados em nome do escritório	CRÍTICO	Apagar já; site novo
2.2	Conta de administrador desconhecida (`admin`)	CRÍTICO	Apagar; mudar todas as palavras-passe
2.3	WordPress, PHP e plugins sem atualizações de segurança	CRÍTICO	Site novo; desligar WordPress
2.4	Site e email no mesmo servidor e na mesma conta	ALTO	Palavras-passe, 2FA, rever email
2.5	Utilizadores, pastas e versões visíveis a qualquer pessoa; login aberto	MÉDIO	Desaparece com o site novo
2.6	Conteúdo de demonstração do tema publicado como se fosse real	MÉDIO	Desaparece com o site novo
2.7	Ligações para domínios que já não existem ("Parceiros")	MÉDIO	Retirar; o site novo não as tem
2.8	Sem cabeçalhos de segurança no site	BAIXO	O site novo já os tem
2.9	Pormenores de DNS e email (SPF, DNSSEC, `.eu`)	BAIXO	Corrigir na migração
2.10	Reputação, certificado, DKIM/DMARC, registo do domínio	OK	Manter

2 O que foi encontrado

Cada ponto indica o que foi encontrado, porque é perigoso e como se resolve. As capturas de ecrã foram feitas a 6 de novembro de 2026. As páginas com spam foram abertas com o JavaScript desligado, para não executar código que lá possa estar.

2.1 Artigos de spam publicados no site

CRÍTICO

O que encontrámos

O mapa do site (`wp-sitemap.xml`), que o WordPress entrega aos motores de busca, lista 9 artigos. **5 são spam** colocado por terceiros:

Data	Endereço	Conta usada
22/10/2023	`/ableton-10-1-6-mac-crack/`	n.º 1
28/11/2024	`/adobe-premiere-pro-transitions-pack-crack/`	n.º 101012 (`admin`)
11/12/2024	`/replica-rolex-gmt-master-ii-126711-.../`	n.º 1
16/12/2024	`/ableton-11-3-4-crack/`	n.º 1
17/12/2024	`/photoshop-download-with-crack/`	n.º 1

Os artigos usam o design do site, com o cabeçalho, o telefone e o email do escritório (figuras 2 e 3).

Porque é perigoso

- **Reputação:** um escritório de advogados a promover software pirateado e contrafação de marcas, com o seu nome e contactos.
- **Motores de busca:** este tipo de spam existe para usar a reputação do domínio e subir páginas de terceiros no Google. Se o Google o detetar, pode penalizar o domínio inteiro ou mostrar avisos nos resultados.
- **Sinal de controlo:** quem publicou estes artigos teve acesso de escrita ao site durante pelo menos 14 meses e pode ainda ter.

Como resolver

- Apagar já os 5 artigos (e esvaziar o lixo do WordPress).
- Com o site novo, os endereços de spam passam a responder "página não encontrada" (404). É isso que leva o Google a esquecê-los: o mapa de redirecionamentos do site novo não os inclui de propósito.
- No Google Search Console, pedir a remoção destes endereços e consultar "Problemas de segurança" (secção 4.5).

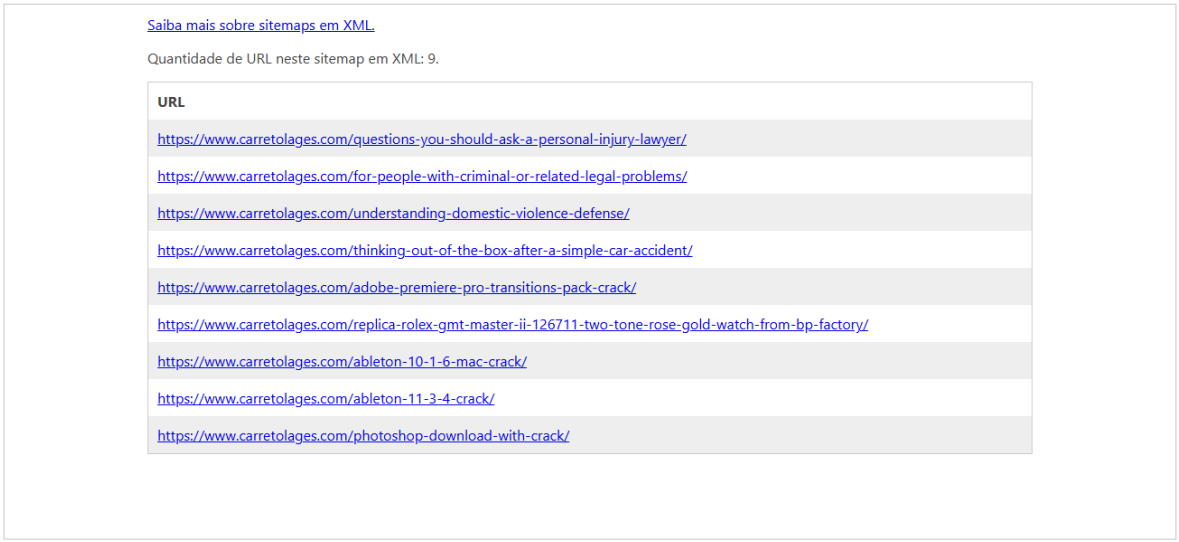
2.2 Conta de administrador desconhecida

CRÍTICO

O que encontrámos

A interface pública do WordPress (`/wp-json/wp/v2/users`) lista três contas (figura 4):

- n.º 1, uma conta pessoal;
- n.º 2, `TecniMobile Lda`, a empresa que fez o site;
- **n.º 101012,** `admin`.



Saiba mais sobre sitemaps em XML.

Quantidade de URL neste sitemap em XML: 9.

URL
https://www.carretolages.com/questions-you-should-ask-a-personal-injury-lawyer/
https://www.carretolages.com/for-people-with-criminal-or-related-legal-problems/
https://www.carretolages.com/understanding-domestic-violence-defense/
https://www.carretolages.com/thinking-out-of-the-box-after-a-simple-car-accident/
https://www.carretolages.com/adobe-premiere-pro-transitions-pack-crack/
https://www.carretolages.com/replica-rolex-gmt-master-ii-126711-two-tone-rose-gold-watch-from-bp-factory/
https://www.carretolages.com/ableton-10-1-6-mac-crack/
https://www.carretolages.com/ableton-11-3-4-crack/
https://www.carretolages.com/photoshop-download-with-crack/

Figura 1. Mapa do site público: 5 dos 9 artigos são spam (cracks e réplicas).

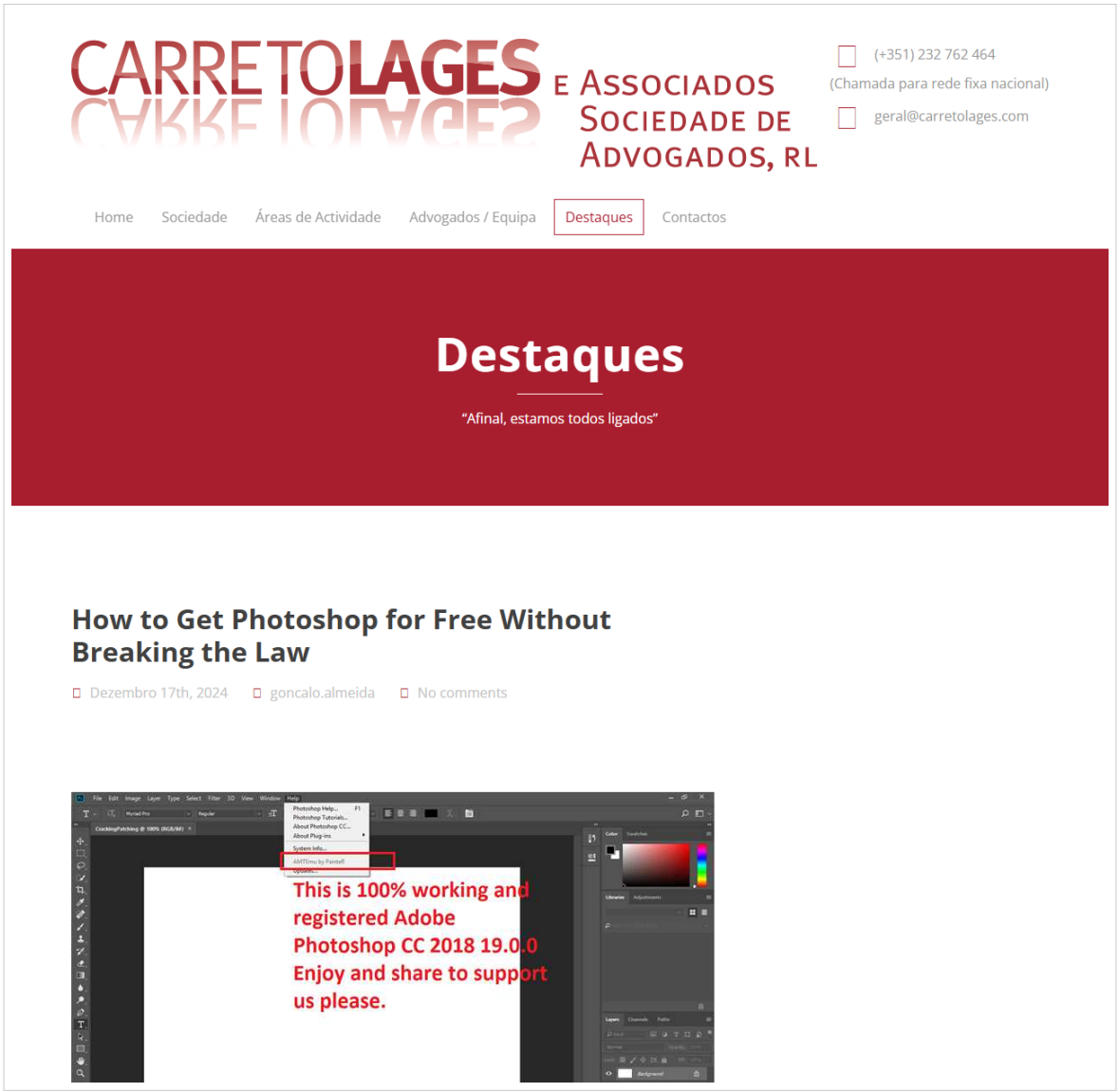


Figura 2. Artigo de spam "How to Get Photoshop for Free" com o cabeçalho e os contactos do escritório.

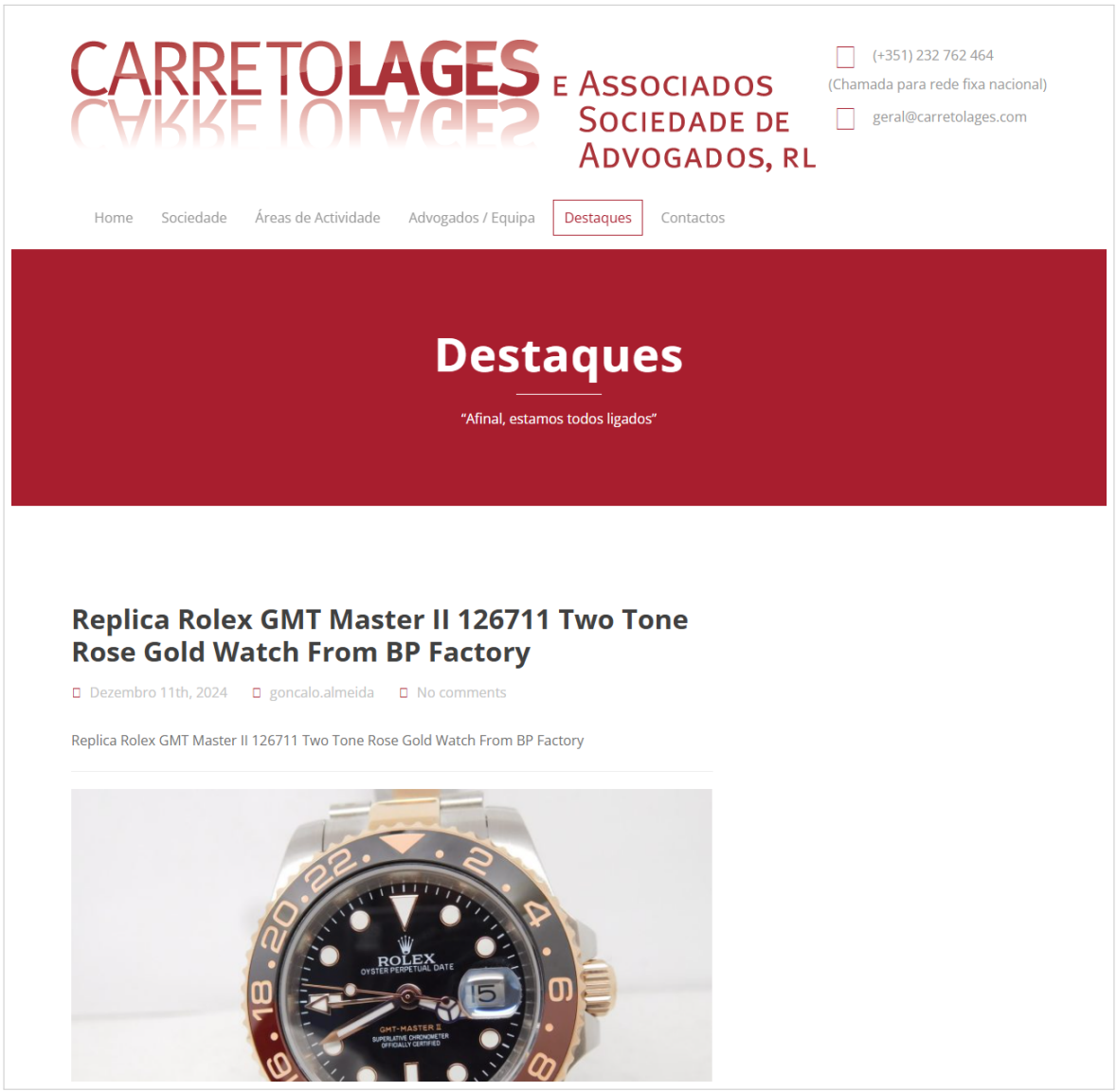


Figura 3. Artigo de spam a promover réplicas de relógios Rolex.

O WordPress numera as contas por ordem (1, 2, 3…). Um número como 101012 não resulta do uso normal: é típico de contas inseridas diretamente na base de dados por um atacante, para manter o acesso mesmo que as palavras-passe mudem. Foi esta conta que publicou o artigo de 28/11/2024 (figura 5). Os outros 4 artigos de spam aparecem em nome da conta n.º 1, o que indica que também essa conta, ou a base de dados, está nas mãos do atacante.

Porque é perigoso

Quem tem uma conta de administrador controla o site inteiro: pode publicar, instalar plugins com código próprio, alterar formulários para recolher dados de visitantes e, através do código, chegar a ficheiros do alojamento.

Como resolver

- Apagar a conta `admin` (n.º 101012) e atribuir os conteúdos a outra conta.
- Mudar as palavras-passe de todas as contas do WordPress e da base de dados, e regenerar as chaves de segurança do `wp-config.php`. Isto termina as sessões abertas.
- Como a conta foi provavelmente criada na base de dados, assumir que o atacante pode ter deixado outros acessos (ficheiros PHP escondidos). Por isso a solução definitiva é **desligar o WordPress** e usar o site novo, que não tem base de dados nem login.

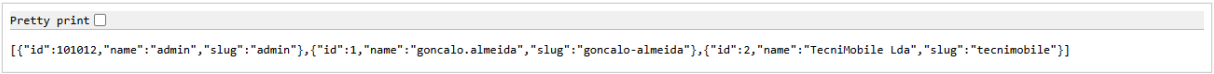


Figura 4. Lista pública de utilizadores: a conta `admin` com o número anómalo 101012.

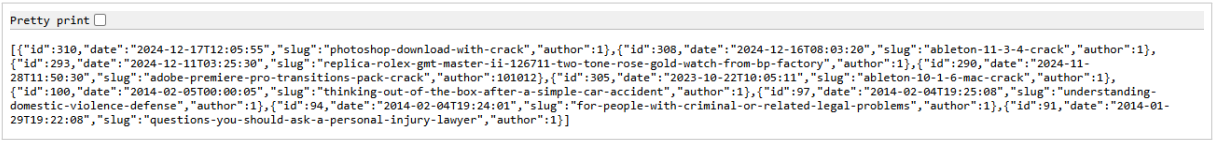


Figura 5. Lista pública de artigos, com a data e a conta que publicou cada um.

2.3 Software sem atualizações de segurança

CRÍTICO

O que encontrámos

Componente	Instalado	Atual	Estado
WordPress	6.1.7	7.1.4	marcado “insecure” pelo próprio WordPress
PHP (servidor)	7.4.33	8.x	sem atualizações de segurança desde novembro de 2022
WPBakery Page Builder	4.11.1	—	versão de 2016
Cookie Notice	2.4.7	3.1.18	desatualizado
jQuery	3.6.1	—	desatualizado
Tema	“lawyers”	—	tema comercial de demonstração

A classificação “insecure” vem do serviço oficial do WordPress que diz a cada site se a sua versão é segura (`https://api.wordpress.org/core/stable-check/1.0/`). O servidor também anuncia a versão do PHP em cada resposta (`X-Powered-By: PHP/7.4.33`).

Porque é perigoso

Versões antigas têm falhas públicas e documentadas, com ferramentas automáticas que as procuram em milhares de sites por dia. É muito provável que tenha sido assim que o site foi atacado.

Como resolver

Atualizar tudo seria possível, mas o tema e o WPBakery de 2016 dificilmente funcionam em versões atuais, e a atualização não remove acessos que o atacante já tenha deixado. **Recomendamos não investir no WordPress**: o site novo substitui-o e o WordPress é desligado logo a seguir à mudança. Até lá, o mínimo é fazer o que está na secção 3.

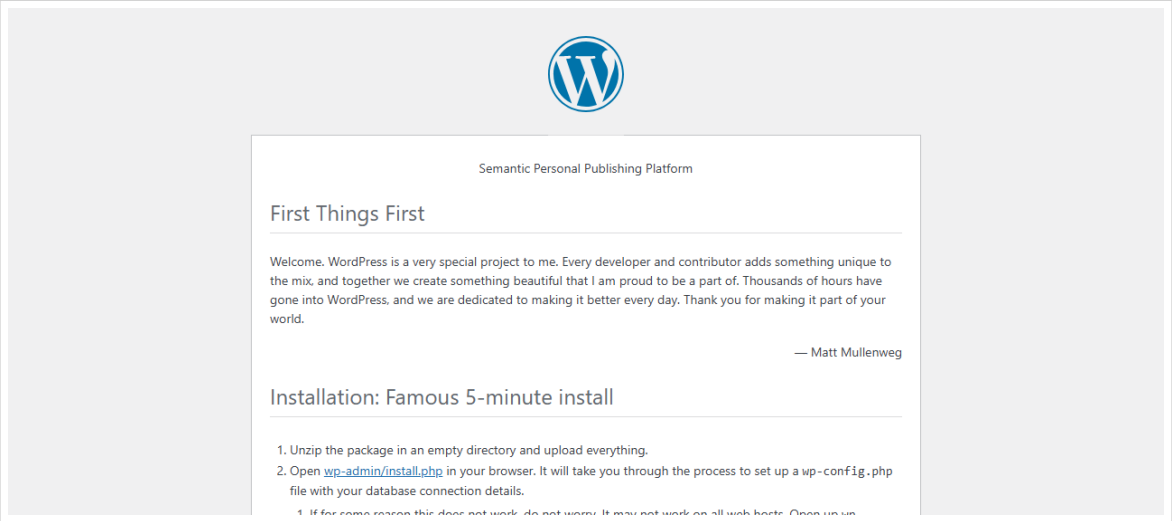


Figura 6. Ficheiro `readme.html` do WordPress, acessível a qualquer pessoa.

2.4 Site e email no mesmo servidor

ALTO

O que encontrámos

O site, o email (`mail`, `webmail`, `autodiscover`) e o painel de alojamento (`cpanel`, `whm`, `ftp`) estão todos no mesmo servidor da PTisp, `130.185.84.194`. O registo SPF do domínio, que diz que servidores podem enviar email em nome de `@carretolages.com`, autoriza esse servidor.

Porque é perigoso

- Código malicioso no site pode enviar email a partir desse servidor, e esse email pode passar as verificações anti-spam dos destinatários por vir de um servidor autorizado. É o cenário ideal para burlas com faturas ou pedidos de transferência "em nome do escritório".
- Se o atacante obteve credenciais do alojamento (cPanel), pode ler caixas de correio, criar contas de email ou criar reencaminhamentos silenciosos que copiam o correio para fora.

Como resolver

- Mudar as palavras-passe da área de cliente PTisp, do cPanel, do FTP e de **todas** as caixas de email. Ativar a autenticação em dois passos (2FA) na área de cliente PTisp.
- No cPanel, verificar se há contas de email, reencaminhadores ("Forwarders") ou filtros que ninguém do escritório criou. No webmail de cada pessoa, verificar regras de reencaminhamento.
- Pedir à PTisp uma análise de malware ao alojamento e os registos de acesso desde 2023.
- Com o site na Cloudflare e o WordPress desligado, o servidor da PTisp fica apenas com o email. Pode valer a pena perguntar à PTisp por um plano só de email.

2.5 Informação exposta e login aberto

MÉDIO

O que encontrámos

- **Nomes de utilizador públicos:** `/wp-json/wp/v2/users` e `/?author=1` revelam os nomes de login, que são metade do que é preciso para entrar.
- **Listagem de pastas:** `/wp-content/uploads/` e `/wp-includes/` mostram o conteúdo das pastas, como um explorador de ficheiros (figuras 7 e 8).
- **Página de login aberta:** `/wp-login.php` aceita tentativas de qualquer lado, sem limite visível (figura 9).
- **Versões anunciadas:** `readme.html`, a etiqueta `generator` e o cabeçalho `X-Powered-By` dizem exatamente que versões atacar.

Porque é perigoso

Juntas, estas informações permitem tentar palavras-passe de forma automática contra contas conhecidas e escolher as falhas certas para as versões instaladas.

Como resolver

Tudo isto desaparece com o site novo, que é composto só por ficheiros estáticos, sem login, sem base de dados e sem listagem de pastas. Até à mudança, a PTisp pode desligar a listagem de pastas ("Indexes" no cPanel) e limitar o acesso a `wp-login.php`.

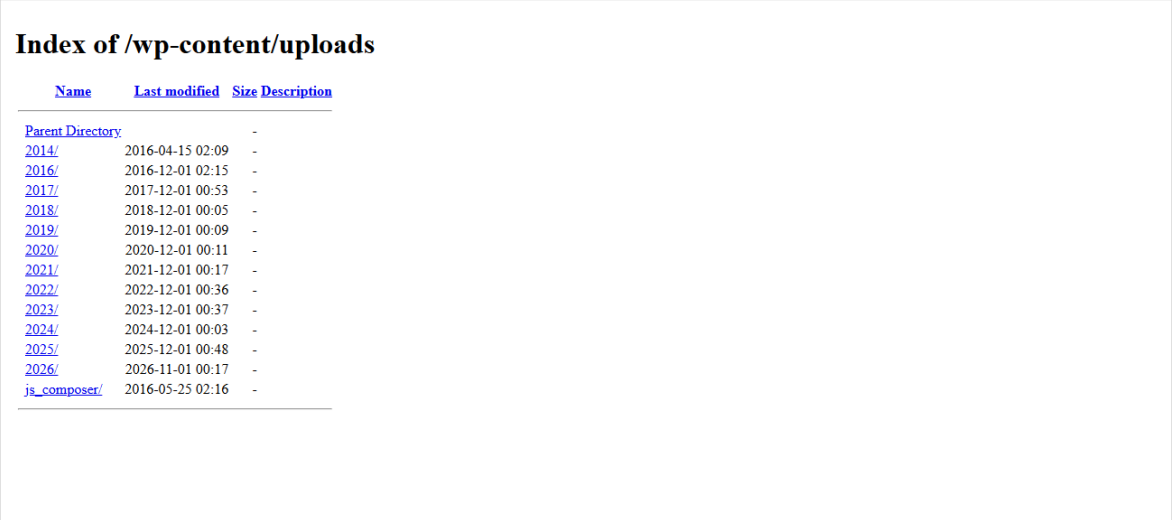


Figura 7. Listagem pública da pasta de ficheiros carregados.

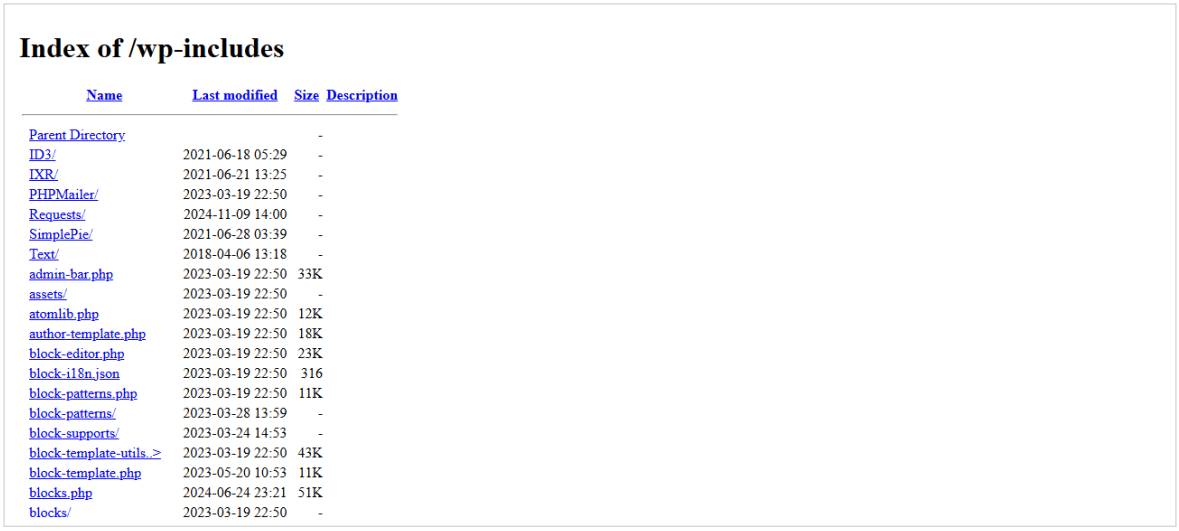
2.6 Conteúdo de demonstração publicado

MÉDIO

O que encontrámos

Continuam publicadas páginas que vieram com o tema e nunca foram substituídas:

- 4 artigos em inglês sobre "personal injury lawyer" e "car accident";
- 4 "resultados de casos" fictícios ("Auto Accident", "Medical Malpractice", "Domestic Violence", "Motocycle Accident");
- 4 testemunhos de exemplo;
- páginas "Página exemplo", "2 Columns" e "page2-2".



Index of /wp-includes

Name	Last modified	Size	Description
Parent Directory		-	
ID3/	2021-06-18 05:29	-	
IXR/	2021-06-21 13:25	-	
PHPMailer/	2023-03-19 22:50	-	
Requests/	2024-11-09 14:00	-	
SimplePie/	2021-06-28 03:39	-	
Text/	2018-04-06 13:18	-	
admin-bar.php	2023-03-19 22:50	33K	
assets/	2023-03-19 22:50	-	
atomlib.php	2023-03-19 22:50	12K	
author-template.php	2023-03-19 22:50	18K	
block-editor.php	2023-03-19 22:50	23K	
block-i18n.json	2023-03-19 22:50	316	
block-patterns.php	2023-03-19 22:50	11K	
block-patterns/	2023-03-28 13:59	-	
block-supports/	2023-03-24 14:53	-	
block-template-utils..>	2023-03-19 22:50	43K	
block-template.php	2023-05-20 10:53	11K	
blocks.php	2024-06-24 23:21	51K	
blocks/	2023-03-19 22:50	-	

Figura 8. Listagem pública da pasta interna `wp-includes`.

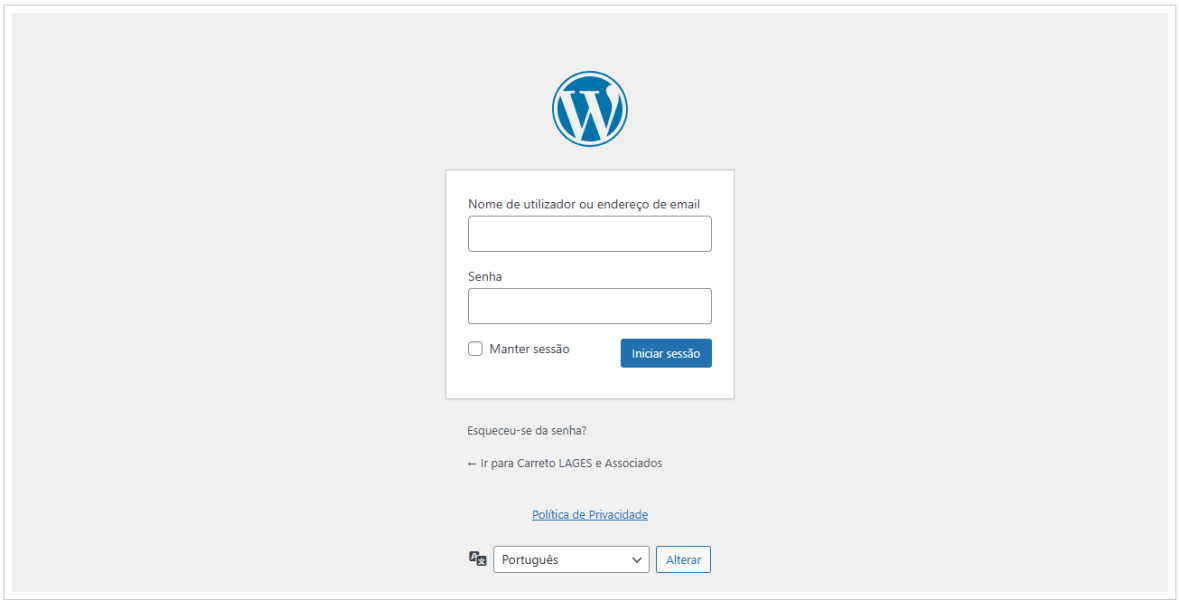


Figura 9. Página de login do WordPress acessível a qualquer pessoa.

Porque é perigoso

Estas páginas são indexadas como sendo do escritório e apresentam casos e testemunhos que não existem. Isso prejudica a credibilidade e pode ser incompatível com as regras de publicidade da Ordem dos Advogados.

Como resolver

O site novo não tem estas páginas. Os endereços antigos com algum valor redirecionam para a página nova equivalente (anexo A). **Atenção:** o site novo também mostra, por decisão do escritório, conteúdo de exemplo (testemunhos, casos e artigos) com o selo "Exemplo ilustrativo". Esse conteúdo deve ser substituído por conteúdo real ou retirado logo que possível, pelas mesmas razões.

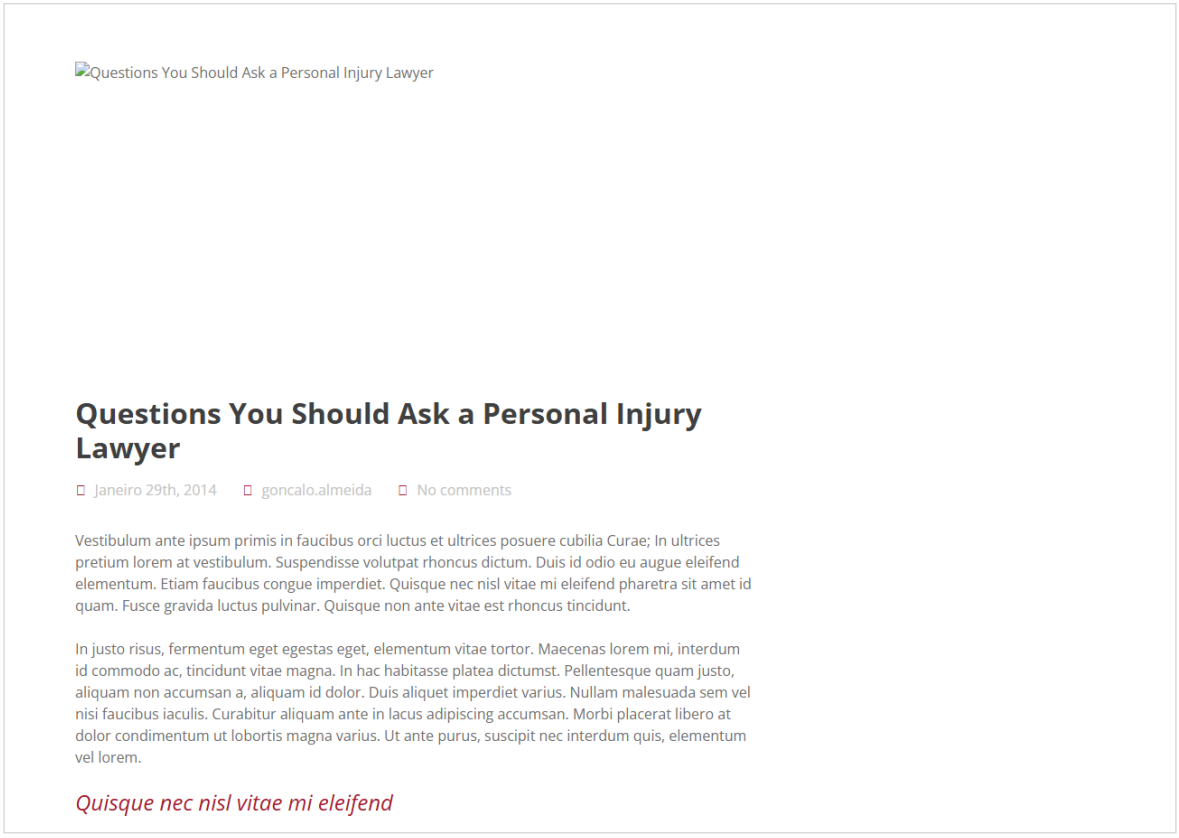


Figura 10. Artigo de demonstração do tema, em inglês, publicado em nome do escritório.

2.7 Ligações para domínios abandonados

MÉDIO

O que encontrámos

A secção "Parceiros" da página inicial liga para `cristina-lanca-advogada.com` e `jpalmslaw-firm.com` (figura 12). Nenhum dos dois domínios está registado (consulta ao registo `.com` a 6/11/2026).

Porque é perigoso

Qualquer pessoa pode registar estes domínios por poucos euros e pôr lá o que quiser, por exemplo uma página falsa ou malware, e o site do escritório continua a enviar visitantes para lá.

Como resolver

Retirar as ligações. O site novo não as inclui.

2.8 Sem cabeçalhos de segurança

BAIXO

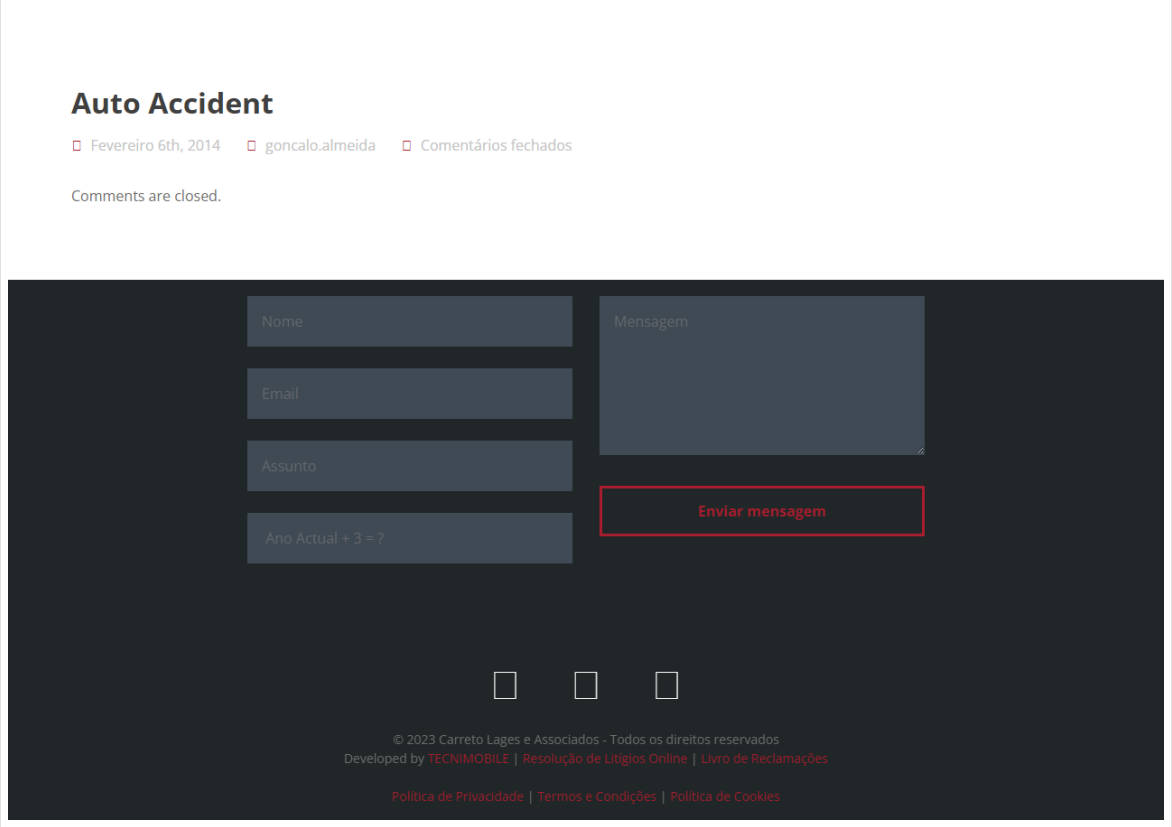


Figura 11. "Resultado de caso" de demonstração ("Auto Accident").

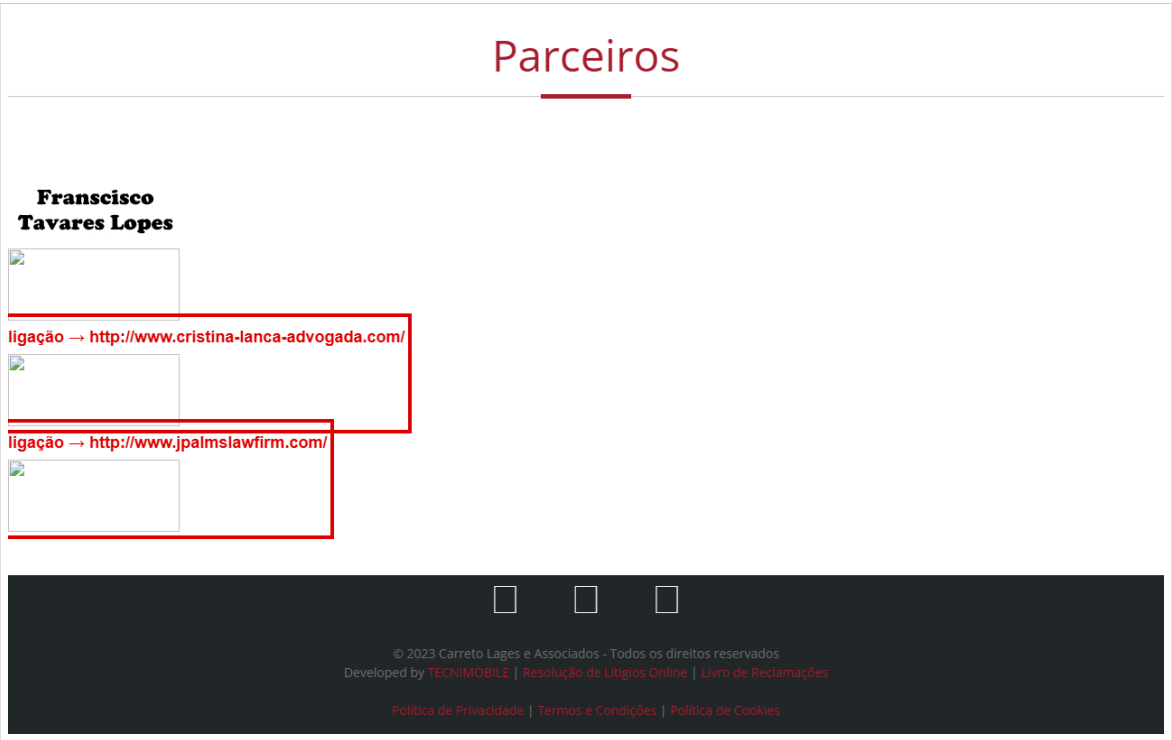


Figura 12. Secção "Parceiros": as ligações assinaladas apontam para domínios que já não existem (o endereço de cada ligação foi escrito a vermelho na captura, para se ler).

O que encontrámos

O site atual não envia nenhum dos cabeçalhos HTTP que os navegadores usam para limitar ataques.

Cabeçalho	Site atual	Site novo
`Strict-Transport-Security` (HTTPS obrigatório)	não	sim
`Content-Security-Policy` (bloqueia scripts externos)	não	sim, estrita
`X-Frame-Options` / `frame-ancestors` (anti-clickjacking)	não	sim
`X-Content-Type-Options`	não	sim
`Referrer-Policy`	não	sim
`Permissions-Policy` (câmara, microfone, localização)	não	sim
Anuncia versão do PHP (`X-Powered-By`)	sim	não

Como resolver

O site novo já tem todos estes cabeçalhos (ficheiro `public/_headers`), testados automaticamente.

2.9 DNS e email: pormenores a corrigir

BAIXO

O que encontrámos

- **SPF de `carretolages.com`:**
  `v=spf1 +a +mx +include:_spf.cleanmx.pt ip4:130.185.84.194 -all`
  O `+a` autoriza "o servidor do site". Depois da mudança, o site passa a ser a Cloudflare, e o `+a` passaria a autorizar os servidores da Cloudflare a enviar email em nome do escritório. Tem de sair. O IP do servidor de email já está escrito no registo.
- **SPF de `carretolages.eu`:** autoriza um endereço de rede privada (`192.168.1.90`), vários IPs externos sem explicação (um deles repetido) e termina em `~all` ("aceitar com desconfiança"). Deve ser limpo.
- `mail.carretolages.com` é um "alias" do domínio principal. Na mudança, se ficar assim, passa a apontar para a Cloudflare e o Outlook e os telemóveis deixam de receber email. **É o ponto mais delicado da migração.**
- **Certificado do email:** o servidor da PTisp usa um certificado `*.carretolages.com` válido até 3/01/2027. Os certificados com `*` são renovados através do DNS. Com o DNS na Cloudflare, é preciso confirmar com a PTisp que a renovação continua a funcionar para `mail` e `webmail`. Caso contrário, os programas de email mostram avisos de certificado a partir de janeiro.
- **DNSSEC** (assinatura do DNS contra falsificação) não está ativo.

Como resolver

Tudo é tratado nos passos da secção 4.

2.10 O que está bem

OK

- **Google Safe Browsing:** "Nenhum conteúdo inseguro encontrado" (figura 13).
- **Listas negras:** nem o servidor nem o domínio constam das listas consultadas (Spamhaus ZEN e DBL, SpamCop, Barracuda, UCEPROTECT, PSBL, SURBL).
- **Email autenticado:** DKIM (seletor `default`) e DMARC com política `p=reject` e alinhamento estrito, a configuração mais protetora. Têm de ser copiados exatamente na migração.

- **Sem "cloaking":** o Google vê o mesmo conteúdo que um visitante (comparação das respostas para o robô do Google e para um navegador).
- **Certificado HTTPS** válido (Let's Encrypt, até 3/01/2027) para `.com` e `.eu`; `http://` e o domínio sem `www` redirecionam para `https://www.`
- **Registo do domínio:** registado desde 2007 na NetEarth (revendedor da PTisp), com bloqueio de transferência ativo, **expira a 6/11/2027**. Convém confirmar que a renovação automática está ligada.

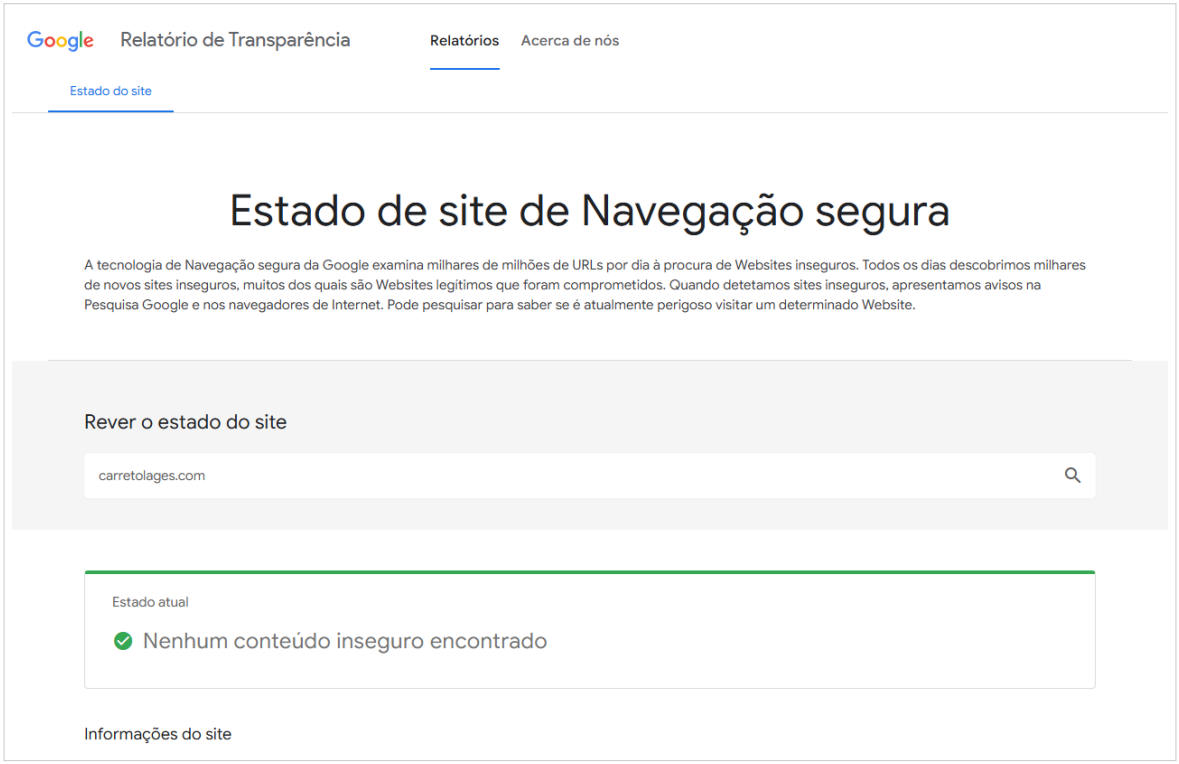


Figura 13. Google Safe Browsing: sem conteúdo inseguro detetado (6/11/2026).

3 O que fazer já, antes da mudança

Estes passos não dependem do site novo e devem ser feitos esta semana, pelo escritório ou pela PTisp.

1. **Palavras-passe novas e diferentes** para a área de cliente PTisp (com 2FA), o cPanel, o FTP, todas as caixas de email e todas as contas do WordPress.
2. **Apagar a conta `admin`** (n.º 101012) no WordPress.
3. **Apagar os 5 artigos de spam** e esvaziar o lixo.
4. **Verificar o email:** contas, reencaminhadores e filtros no cPanel; regras de reencaminhamento no webmail de cada pessoa.
5. **Pedir à PTisp** uma análise de malware ao alojamento, a desativação da listagem de pastas e informação sobre acessos suspeitos desde 2023.
6. **Não fazer** cópias de segurança do WordPress para reutilizar: estão contaminadas. Se for preciso arquivar textos ou imagens, copiar só esses conteúdos.

4 Passos para passar para a Cloudflare

Princípio: o domínio continua registado na PTisp e o email continua na PTisp. Passam para a Cloudflare apenas o **DNS** (a "lista telefónica" do domínio) e o **site**. O plano gratuito da Cloudflare chega. O custo mensal é 0 €.

Porque o DNS e não só um registo: a Cloudflare Pages só consegue servir o domínio sem `www` quando gere o DNS. Também permite redirecionamentos, DNSSEC e regras sem depender do servidor antigo.

4.1 Fase 0 — Preparação (sem impacto no site nem no email)

1. **Conta Cloudflare do escritório**, criada com um email do escritório e com 2FA. O programador é convidado como membro, para o escritório nunca ficar dependente de uma conta pessoal.
2. **Exportar a zona DNS completa** no cPanel ("Zone Editor") ou pedi-la à PTisp em formato BIND (ficheiro de texto). A análise pública só vê os registos que se sabe procurar. A exportação garante que nada fica esquecido, em particular o DKIM, que é um texto longo e tem de ser copiado exatamente.
3. **Publicar o site** na conta do escritório, com a versão para o domínio (indexável, com o conteúdo de exemplo):

   ```
   npm run build:live
   npx wrangler pages deploy dist --project-name carretolages --branch main
   ```

   O endereço `carretolages.pages.dev` continua sempre com `noindex`, para não competir com o domínio no Google.
4. **Combinar com a PTisp** a renovação do certificado de `mail` e `webmail` depois da mudança do DNS (secção 2.9).

4.2 Fase 1 — Criar a zona na Cloudflare

1. Criar a zona, que fica "pendente" até à mudança dos nameservers:

   ```
   cf zones create --name carretolages.com --type full
   ```

   A resposta indica os **dois nameservers** atribuídos (do tipo `xxx.ns.cloudflare.com`).
2. Importar a zona exportada na fase 0:

   ```
   cf dns records import --zone carretolages.com --file carretolages.com.zone
   ```

3. **Rever registo a registo** e deixar a zona assim ("só DNS" = nuvem cinzenta, sem passar pelo proxy da Cloudflare):

Nome	Tipo	Valor	Proxy
`www`	CNAME	`carretolages.pages.dev` (criado pela Pages)	sim
`@`	CNAME	`carretolages.pages.dev` (criado pela Pages)	sim
`@`	MX 10	`mx1.cleanmx.pt`	—
`@`	MX 20	`mx2.cleanmx.pt`	—
`@`	TXT	`v=spf1 +mx +include:_spf.cleanmx.pt ip4:130.185.84.194 -all`	—
`_dmarc`	TXT	copiar exatamente (`v=DMARC1;p=reject;...`)	—
`default._domainkey`	TXT	copiar exatamente (DKIM)	—
`mail`	**A**	`130.185.84.194` (hoje é CNAME: mudar!)	**não**
`webmail`, `autodiscover`, `autoconfig`	A	`130.185.84.194`	não
`cpanel`, `whm`, `webdisk`, `ftp`	A	`130.185.84.194`	não
`cpcalendars`, `cpcontacts`	A	`130.185.84.194`	não
outros da exportação (ex.: SRV)	—	copiar como estão	não

Os registos antigos `@ A 130.185.84.194` e `www CNAME carretolages.com` saem, porque são substituídos pelos do site novo. **Nada que tenha a ver com email pode ficar com proxy:** a Cloudflare só encaminha tráfego web.

4.3 Fase 2 — Ligar o site ao domínio

1. Associar os dois endereços ao projeto Pages, que cria e valida os registos e os certificados:

   ```
   cf pages projects domains create carretolages --name www.carretolages.com
   cf pages projects domains create carretolages --name carretolages.com
   ```

2. Criar no painel da Cloudflare uma **regra de redirecionamento** (Rules → Redirect Rules, modelo "Redirect from root to WWW"):
   `carretolages.com/*` → `https://www.carretolages.com/$1`, código 301, mantendo o resto do endereço.
3. Em SSL/TLS → Edge Certificates: "Always Use HTTPS" ligado e TLS mínimo 1.2.

Até à fase 3, tudo isto fica preparado mas sem efeito, porque o mundo ainda consulta o DNS da PTisp.

4.4 Fase 3 — Mudar os nameservers (a mudança propriamente dita)

1. Na área de cliente da PTisp: Domínios → `carretolages.com` → Nameservers. Substituir `nsp1`–`nsp4.mydnspt.net` pelos dois nameservers da Cloudflare.
2. **Não apagar nada na PTisp.** Durante a propagação (até 24–48 horas), parte da internet consulta a PTisp e parte a Cloudflare. Como as duas têm os mesmos registos de email, o email funciona sempre. O site mostra o antigo ou o novo, conforme a pessoa.
3. Confirmar que a zona ficou ativa:

   ```
   cf zones get carretolages.com        # "status": "active"
   ```

4. **Testes no próprio dia:**
   - enviar e receber um email de e para `geral@carretolages.com`, a partir de Gmail e de Outlook;

- abrir o email no telemóvel e no Outlook do escritório;
- abrir `https://www.carretolages.com` e `https://carretolages.com`;
- abrir um endereço antigo, por exemplo `/contact/`, e confirmar que vai para `/contactos`;
- abrir `/photoshop-download-with-crack/` e confirmar que dá "página não encontrada".

Plano de recuo: se algo falhar, repor os nameservers da PTisp na área de cliente. A zona antiga continua intacta lá, por isso volta tudo ao estado anterior em poucas horas.

4.5 Fase 4 — Depois da mudança

1. **DNSSEC:** ativar na Cloudflare e colar o registo DS que a Cloudflare indica na área de cliente da PTisp:

   ```
   cf dns dnssec edit --zone carretolages.com --status active
   ```

2. **Google Search Console:** verificar o domínio com um registo TXT, submeter `https://www.carretolages.com/sitemap-index.xml`, consultar "Problemas de segurança" e pedir a remoção dos 5 endereços de spam.
3. **Desligar o WordPress** uma semana depois, se tudo estiver estável: apagar os ficheiros e a base de dados no cPanel. O plano PTisp fica só com o email.
4. **Domínio `carretolages.eu`:** hoje redireciona através do servidor do WordPress. Para não deixar de funcionar quando o WordPress sair, criar também a zona `carretolages.eu` na Cloudflare com um redirecionamento para `https://www.carretolages.com`, mantendo os registos de email e limpando o SPF (secção 2.9).
5. **Formulário de contacto:** o site novo ainda não envia mensagens. Para as entregar em `geral@carretolages.com` é preciso uma pequena função na Cloudflare e um serviço de envio de email configurado num subdomínio (por exemplo `envio.carretolages.com`), sem tocar no email principal. O Email Routing da Cloudflare não serve, porque obrigaria a passar o MX para a Cloudflare. A escolha do serviço de envio está pendente.

A Endereços antigos e para onde vão

O site novo inclui o ficheiro `public/_redirects`, com redirecionamentos permanentes (301) dos endereços do site antigo (com e sem a barra final). Assim, ligações em favoritos, emails antigos e resultados do Google continuam a funcionar e passam a sua reputação para as páginas novas. Os 5 endereços de spam ficam de fora de propósito.

Endereço antigo	Página nova
`/about/`	`/sociedade`
`/historia/`, `/perfil-e-valores/`, `/pro-bono/`	`/sociedade/...` (mesma página)
`/practice-areas/`	`/areas-de-atuacao`
`/practice-items/direito-penal-e-das-contra-ordenacoes/`	`/areas-de-atuacao/direito-penal`
`/practice-items/direito-imobiliario-e-urbanismo/`	`/areas-de-atuacao/direito-imobiliario`
`/practice-items/direito-fiscal/`	`/areas-de-atuacao/direito-fiscal`
`/practice-items/direito-financeiro-bancario/`	`/areas-de-atuacao/direito-financeiro`
outras 5 áreas antigas (civil, administrativo, comercial, trabalho, seguros)	`/areas-de-atuacao`
`/lawyers/`	`/advogados`

Endereço antigo	Página nova
`/team/jose-carreto-lages/`, `/team/joao-carlos-lages/`, `/team/catarina-pereira-carvalho/`	`/advogados/<mesmo nome>`
`/team/susana-portugal/`, `/team/rita-tavares/`, `/team/ana-mendes/`	`/advogados`
`/blog/` e os 4 artigos de demonstração	`/destaques`
`/case-results-2/` e `/cases/...`	`/casos`
`/contact/`	`/contactos`
`/resolucao-de-litigios-online/`	`/resolucao-de-litigios`
`/faq/`, `/testimonials/`, `/testimonials-list/...`	`/` (página inicial)
`/pagina-exemplo/`, `/2-columns/`, `/page2-2/`	`/` (página inicial)
`/cookies/`, `/termos-e-condicoes/`, `/politica-de-privacidade/`	mesma página (sem barra final)
5 artigos de spam	**404 — não encontrado**

B Como foi feita a análise

- **DNS:** consultas públicas (Cloudflare DNS-over-HTTPS e resolvedor 1.1.1.1) aos registos NS, A, MX, TXT, SPF, DKIM, DMARC, DS e subdomínios comuns de alojamento.
- **Registo do domínio:** RDAP do registo `.com` (Verisign).
- **Site:** pedidos normais (GET) às páginas públicas, ao mapa do site, à interface pública do WordPress e a ficheiros que o WordPress expõe por omissão. Não se tentou nenhum login e não se enviou nenhum formulário. Respostas comparadas entre um navegador e o robô do Google.
- **Versões:** serviço oficial do WordPress (`api.wordpress.org`) e diretório de plugins.
- **Reputação:** Google Safe Browsing e listas negras públicas por DNS.
- **Capturas:** Google Chrome automatizado (`scripts/domain-audit.mjs`), com JavaScript desligado nas páginas com spam. O servidor limita pedidos seguidos (erro 429), por isso as capturas foram feitas com pausas.